Vulnerability Assessment and Penetration Testing (VAPT) Report on Metasploitable3

Task 06 Report :

Name : Manish Tiruwa

Date : 26/03/2026

Environment : Kali Linux (Virtual Machine)

Introduction

This report presents the results of a Vulnerability Assessment and Penetration Testing (VAPT) conducted on the Metasploitable3 virtual machine. The assessment was performed using open-source tools such as Nmap and Nikto in a controlled lab environment.

The objective of this assessment was to identify vulnerabilities, analyze their severity, and recommend mitigation strategies. Several vulnerabilities were discovered, including outdated services, directory listing, and exposed administrative interfaces.

Based on the findings, multiple high and medium risk vulnerabilities were identified, which could lead to unauthorized access and data exposure if not properly mitigated.

OBJECTIVE

The objectives of this VAPT assessment are:

- To identify open ports and running services on the target system
- To detect vulnerabilities using scanning tools
- To assess the risk level of identified vulnerabilities
- To provide recommendations for improving system security

THEORETICAL KNOWLEDGE

Understanding Security Assessment :

Security assessment is the process of identifying vulnerabilities and weaknesses in a system. It helps improve security by detecting risks before attackers can exploit them.

Types of security testing include:

- **Vulnerability Assessment:** Identifies weaknesses using tools such as Nmap and OpenVAS
- **Penetration Testing:** Simulates real-world attacks using tools like Metasploit
- **Compliance Testing:** Ensures systems follow security standards such as CIS Benchmarks

VAPT Methodology :

The VAPT process follows a structured approach:

- **Planning:** Define scope and target
- **Discovery:** Identify open ports and services using Nmap
- **Attack:** Attempt exploitation using Metasploit
- **Reporting:** Document findings and recommendations

The OWASP Web Security Testing Framework was used as a reference.

Security Standards & Compliance :

Security standards help organizations protect data and systems. Common standards include:

- **ISO 27001:** Information security management
- **GDPR:** Data protection regulation
- **HIPAA:** Healthcare data protection

The OWASP Top 10 was used to understand common web vulnerabilities.

Risk Assessment Basics :

Risk assessment helps prioritize vulnerabilities based on their severity.

- **CVSS (Common Vulnerability Scoring System):** Used to assign severity scores
- **Risk Matrix:** Categorizes risks into High, Medium, and Low

Common Vulnerabilities :

Common vulnerabilities identified during testing include:

- Open ports and misconfigured services
- Outdated software versions
- Directory listing and exposed admin panels

METHODOLOGY :

The assessment followed these steps:

- **Planning:** Setup of testing environment
- **Analysis:** Identified vulnerabilities
- **Scanning:** Performed using Nmap and Nikto
- **Exploitation (Optional):** Attempted limited exploitation
- **Reporting:** Documented findings and recommendations

ENVIRONMENT SETUP :

The testing environment was configured using VirtualBox:

- **Attacker Machine:** Kali Linux
- **Target Machine:** Metasploitable3

Both systems were connected using a Host-Only network.

- Kali Linux IP: 192.168.56.20
- Metasploitable3 IP: 192.168.56.10

VULNERABILITY SCANNING

Vulnerability scanning was performed using Nmap and Nikto tools.

- **Nmap** was used to identify open ports and services.
- **Nikto** was used to identify web server vulnerabilities.

OpenVAS was not used due to feed synchronization issues; therefore, manual scanning techniques were applied.

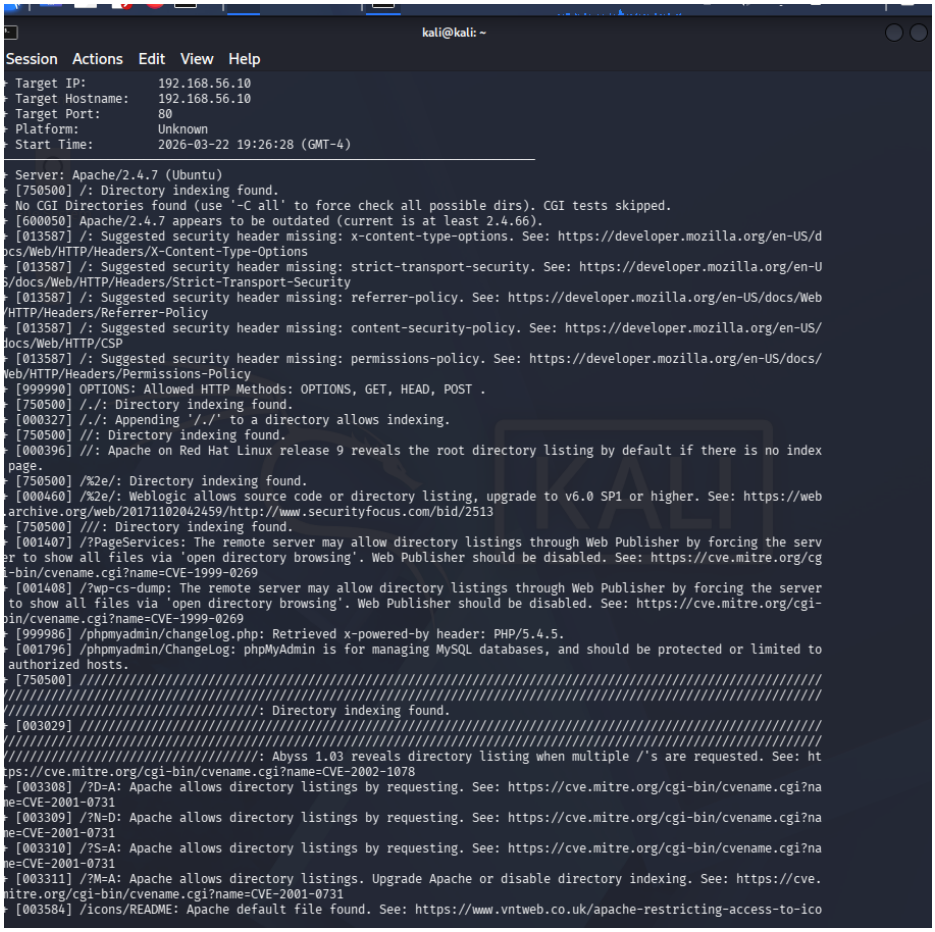
FINDINGS / IDENTIFIED VULNERABILITIES

Nmap Scan Results :

The Nmap scan revealed multiple open ports and services running on the target system.

Open Ports and Services :

Port	Service	Version
21	FTP	ProFTPD 1.3.5
22	SSH	OpenSSH 6.6.1
80	HTTP	Apache 2.4.7
445	SMB	Samba 4.3.11
631	IPP	CUPS 1.7
3306	MySQL	MySQL
8080	HTTP	Jetty


kali@kali: ~
Session Actions Edit View Help
+ Target IP: 192.168.56.10
+ Target Hostname: 192.168.56.10
+ Target Port: 80
+ Platform: Unknown
+ Start Time: 2026-03-22 19:26:28 (GMT-4)
+ Server: Apache/2.4.7 (Ubuntu)
+ [750500] /: Directory indexing found.
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [600050] Apache/2.4.7 appears to be outdated (current is at least 2.4.66).
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [999990] OPTIONS: Allowed HTTP Methods: OPTIONS, GET, HEAD, POST .
+ [750500] /./: Directory indexing found.
+ [000327] /./: Appending '/./' to a directory allows indexing.
+ [750500] //: Directory indexing found.
+ [000396] //: Apache on Red Hat Linux release 9 reveals the root directory listing by default if there is no index page.
+ [750500] /%2e/: Directory indexing found.
+ [000460] /%2e/: Weblogic allows source code or directory listing, upgrade to v6.0 SP1 or higher. See: https://web.archive.org/web/20171102042459/http://www.securityfocus.com/bid/2513
+ [750500] ///: Directory indexing found.
+ [001407] /?PageServices: The remote server may allow directory listings through Web Publisher by forcing the server to show all files via 'open directory browsing'. Web Publisher should be disabled. See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0269
+ [001408] /?wp-cs-dump: The remote server may allow directory listings through Web Publisher by forcing the server to show all files via 'open directory browsing'. Web Publisher should be disabled. See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0269
+ [999986] /phpmyadmin/changelog.php: Retrieved x-powered-by header: PHP/5.4.5.
+ [001796] /phpmyadmin/ChangeLog: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ [750500] ////////////

Vulnerability 2: phpMyAdmin Exposure :

- **Port:** 80
- **Service:** Web Application
- **Description:** phpMyAdmin interface is publicly accessible.
- **Risk Level:** High
- **CVSS Score:** 8.5
- **Impact:** Unauthorized users may gain access to the database.
- **Recommendation:** Restrict access using authentication or IP filtering.

Vulnerability 3: Outdated Apache Version :

- **Port:** 80
- **Service:** Apache 2.4.7
- **Description:** The web server is running an outdated version.
- **Risk Level:** Medium
- **CVSS Score:** 6.5
- **Impact:** Known vulnerabilities can be exploited.
- **Recommendation:** Update Apache to the latest version.

Vulnerability 4: Missing Security Headers :

- **Port:** 80
- **Description:** Important HTTP security headers are missing.
- **Risk Level:** Medium
- **CVSS Score:** 5.0
- **Impact:** Increased risk of XSS and clickjacking attacks.
- **Recommendation:** Implement proper HTTP security headers.

Vulnerability 5: SMB Misconfiguration :

- **Port:** 445
- **Service:** Samba
- **Description:** SMB message signing is disabled.
- **Risk Level:** High
- **CVSS Score:** 8.0
- **Impact:** Allows man-in-the-middle attacks.
- **Recommendation:** Enable SMB signing and secure configurations.

Vulnerability 6: Open MySQL Service :

- **Port:** 3306
- **Service:** MySQL
- **Description:** MySQL service is exposed to the network.
- **Risk Level:** High
- **CVSS Score:** 8.0
- **Impact:** Unauthorized database access possible.
- **Recommendation:** Restrict access and enforce strong authentication.

RISK ASSESSMENT

Risk assessment was performed using CVSS scoring.

Vulnerability	CVSS Score	Risk Level
Directory Listing	7.5	High
phpMyAdmin Exposure	8.5	High
SMB Misconfiguration	8.0	High
MySQL Exposure	8.0	High
Apache Outdated	6.5	Medium
Missing Headers	5.0	Medium

REMEDIATION

The following steps are recommended :

- Update all outdated software
- Disable directory listing
- Secure phpMyAdmin access
- Enable SMB signing
- Restrict database access
- Implement HTTP security headers

REFERENCES

- Nmap Documentation
- Nikto Tool
- OWASP Top 10
- CVSS Calculator

CONCLUSION

The VAPT assessment successfully identified multiple vulnerabilities in the Metasploitable3 system. Several high-risk issues were found, including exposed services and misconfigurations. Proper security measures and updates are recommended to mitigate these risks and improve system security.

OpenVAS / GVM Limitation Note

During the practical implementation, OpenVAS (Greenbone Vulnerability Manager) was initially planned for vulnerability scanning. However, the setup process encountered technical issues related to feed synchronization.

The feed update process was taking an unusually long time and the scanner remained in a "still starting" state, which prevented successful scan configuration and execution.

Due to time constraints and resource limitations, the OpenVAS scanning process was skipped, and alternative open-source tools such as Nmap and Nikto were used to perform vulnerability assessment.

These tools provided sufficient and reliable results for identifying vulnerabilities and completing the assessment effectively.

I apologize for the delay and inconvenience caused due to the technical issues encountered during the GVM setup.